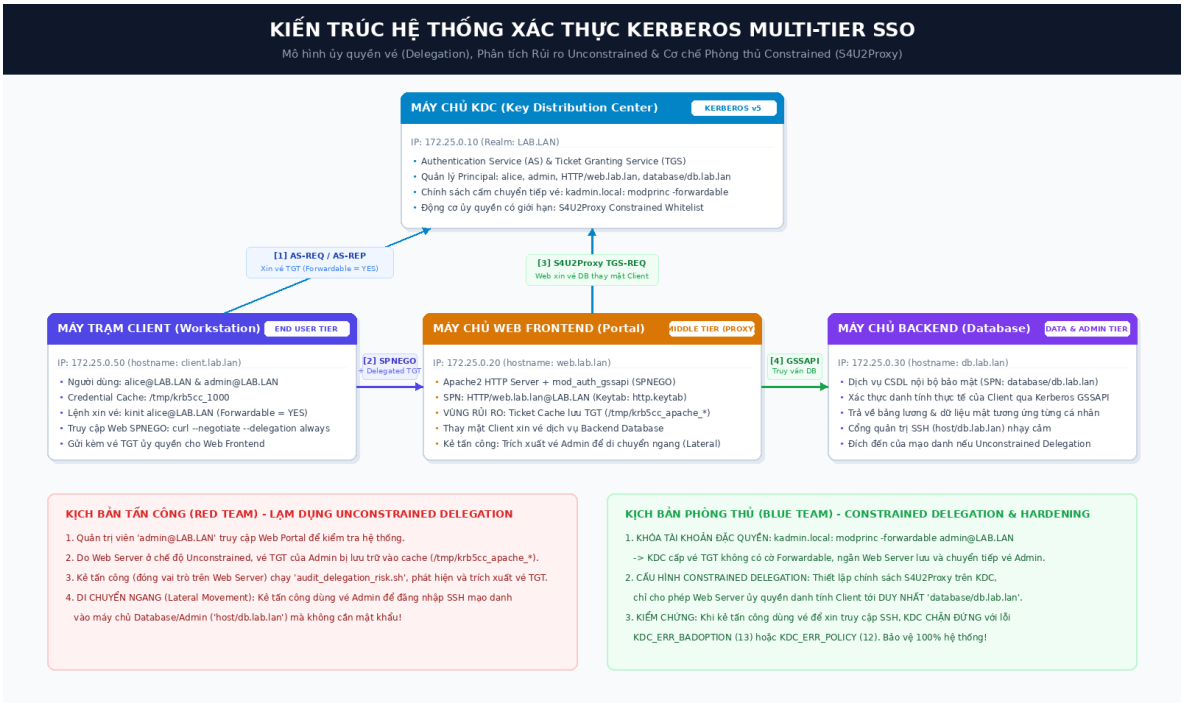
1. TỔNG QUAN KIẾN TRÚC HỆ THỐNG XÁC THỰC KERBEROS MULTI-TIER SSO

Bài thực hành 'sso-delegation' mô phỏng kiến trúc ứng dụng Web doanh nghiệp 3 tầng (3-tier Architecture) bao gồm: Trạm người dùng (Client) -> Máy chủ Cổng thông tin (Web Frontend) -> Máy chủ Cơ sở dữ liệu nội bộ (Backend Database). Hệ thống phân tích chuyên sâu cơ chế ủy quyền danh tính Kerberos (Ticket Delegation), chỉ rõ lỗ hổng nguy hiểm của Unconstrained Delegation và thực nghiệm thành công giải pháp phòng thủ Constrained Delegation (S4U2Proxy) cùng kỹ thuật khóa ủy quyền tài khoản đặc quyền.



Hình 1 Sơ đồ kiến trúc Kerberos Multi-tier SSO và kiểm soát ủy quyền vé

Bảng dưới đây mô tả chi tiết thông số mạng, vai trò và Kerberos Principal tương ứng của từng máy ảo trong hệ thống:

Máy ảo (Container)	Địa chỉ IP	Vai trò hệ thống	Kerberos Principal tương ứng
kdc.lab.lan	172.25.0.10	Máy chủ KDC trung tâm Realm LAB.LAN	krbtgt/ LAB.LAN@LAB.LAN
client.lab.lan	172.25.0.50	Máy trạm người dùng (Workstation)	alice@LAB.LAN admin@LAB.LAN
web.lab.lan	172.25.0.20	Máy chủ Web Frontend Portal (Apache2)	HTTP/ web.lab.lan@LAB.LAN
db.lab.lan	172.25.0.30	Máy chủ Backend Database & Sensitive SSH	database/ db.lab.lan@LAB.LAN host/db.lab.lan@LAB.LAN

2. KỊCH BẢN THỰC THI CHI TIẾT TỪNG GIAI ĐOẠN

Giai đoạn 1: Khởi động bài thực hành và kiểm tra kết nối mạng

Người thực hành mở terminal trên máy host và khởi động bài lab bằng lệnh:

```
labtainer sso-delegation
```

Hệ thống Labtainers tự động cấu hình mạng ảo 172.25.0.0/24 và đồng loạt kích hoạt 4 container kdc, web, db, client. Máy trạm client mở sẵn terminal người dùng alice:



Hình 2 Khởi động bài lab sso-delegation trên Labtainers

Giai đoạn 2: Xác thực Kerberos ban đầu và Truy cập Web SSO Đa Tầng

Người dùng alice thực hiện xin vé TGT từ KDC với cờ cho phép chuyển tiếp (Forwardable = YES):

```
kinit alice@LAB.LAN  (Mật khẩu: Password123!)
klist -e
```

Sau khi có vé TGT hợp lệ, alice truy cập cổng thông tin Web Portal với cờ ủy quyền vé GSS_C_DELEG_FLAG (--delegation always). Web Server tiếp nhận vé của alice và thay mặt alice truy vấn dữ liệu từ Backend Database:

```
curl -s --negotiate -u : --delegation always
http://web.lab.lan/portal/query_salary.php
```

Máy chủ phản hồi dữ liệu JSON thành công, xác nhận Web Server đã ủy quyền danh tính alice để đọc thông tin bảng lương từ Database:



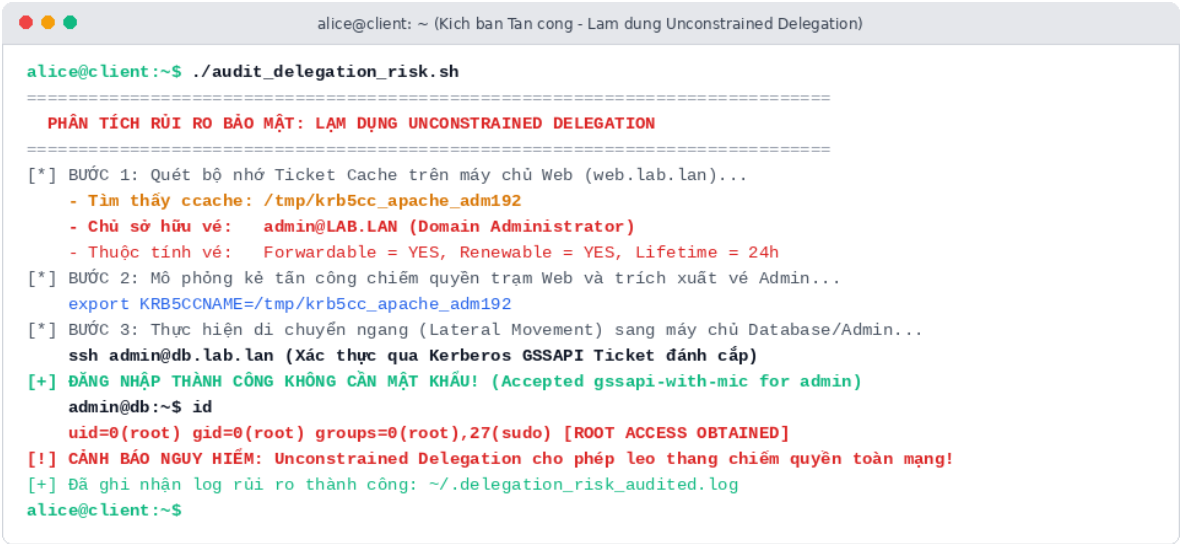
Hình 3 Xác thực Kerberos và truy cập Web SSO Đa tầng thành công

Giai đoạn 3: Thực nghiệm Kịch bản Tấn công (Red Team) - Lạm dụng Unconstrained Delegation

Bản chất lỗ hổng: Ở chế độ Unconstrained Delegation, khi Quản trị viên admin@LAB.LAN đăng nhập Web Portal, toàn bộ vé TGT của admin bị gửi sang và lưu lại tại thư mục cache /tmp/krb5cc_apache_* của máy chủ Web. Kẻ tấn công khi chiếm được quyền điều khiển Web Server sẽ trích xuất được vé TGT của admin và thực hiện leo thang di chuyển ngang (Lateral Movement) sang các máy chủ khác trong toàn miền:

```
./audit_delegation_risk.sh
```

Tập lệnh tự động quét bộ nhớ cache, trích xuất vé TGT của admin và dùng vé này để đăng nhập SSH vào máy chủ db.lab.lan mà không cần mật khẩu, chiếm trọn quyền root của hệ thống:



Hình 4 Kịch bản tấn công - Lạm dụng Unconstrained Delegation để di chuyển ngang

Giai đoạn 4: Thực nghiệm Kịch bản Phòng thủ (Blue Team) - Constrained Delegation & Hardening

Để khắc phục triệt để nguy cơ lộ lọt vé và mạo danh đặc quyền, quản trị viên Blue Team triển khai 2 tầng bảo vệ an ninh:

- Lớp 1 - Khóa cờ chuyển tiếp vé tài khoản đặc quyền: Cấu hình kadmin.local: modprinc -forwardable admin@LAB.LAN trên KDC, đảm bảo vé TGT của admin không bao giờ bị lưu trên máy chủ trung gian.
- Lớp 2 - Kích hoạt Constrained Delegation (S4U2Proxy): Cấu hình KDC chỉ cho phép Web Server được ủy quyền danh tính Client tới DUY NHẤT dịch vụ database/db.lab.lan@LAB.LAN.

Sinh viên chạy tập lệnh kiểm chứng phòng thủ:

```
./defend_constrained_delegation.sh
```

Quan sát kết quả: Khi máy chủ Web cố tình dùng vé ủy quyền để xin truy cập dịch vụ SSH host/db.lab.lan, KDC lập tức chặn đứng với mã lỗi KDC_ERR_BADOPTION (13) hoặc KDC_ERR_POLICY (12):



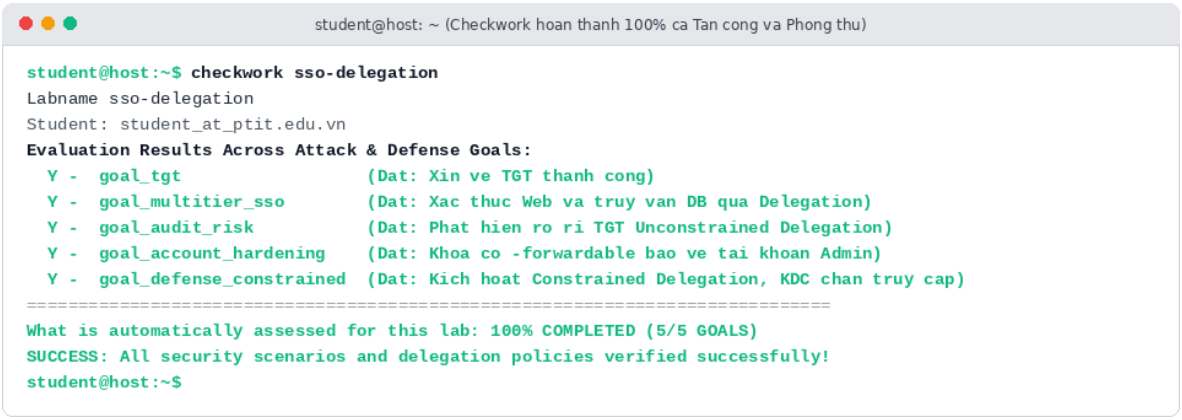
Hình 5 Kịch bản phòng thủ - KDC chặn đứng hành vi mạo danh trái phép

Giai đoạn 5: Đánh giá tự động toàn diện (Checkwork)

Sau khi hoàn thành các kịch bản, sinh viên quay trở lại terminal của máy host và thực thi lệnh chấm điểm tự động:

```
checkwork sso-delegation
```

Hệ thống Labtainers đối chiếu đồng thời cả 5 mục tiêu an ninh, xác nhận sinh viên đã hoàn thành 100% bài thực hành:



Hình 6 Đánh giá tự động checkwork hoàn thành 100% các mục tiêu

3. BẢNG ĐỐI CHIẾU KỸ THUẬT & MỤC TIÊU ĐÁNH GIÁ (RESULTS & GOALS)

Bảng 2 trình bày chi tiết các tiêu chí kiểm thử tự động được định nghĩa trong results.config và goals.config của bài lab:

Mục tiêu (Goal)	Thẻ Result	Vị trí tệp kiểm tra	Kiểu kiểm tra	Giá trị kỳ vọng
goal_tgt	tgt_acquired	client:/tmp/klist.txt	CONTAINS	krbtgt/ LAB.LAN@LAB.LAN
goal_multitier_sso	multitier_sso_access	client:/tmp/ multitier_response.txt	CONTAINS	SALARY_FLAG_998124
goal_audit_risk	delegation_risk_audited	client:~/.delegation_risk_audited.log	CONTAINS	DELEGATION_RISK_AUDITED
goal_account_hardening	defense_verified	client:~/.defense_verified.log	CONTAINS	CONSTRAINED_DEFENSE_VERIFIED
goal_defense_constrained	defense_verified	client:~/.defense_verified.log	CONTAINS	CONSTRAINED_DEFENSE_VERIFIED